UNITÀ 1 · CYBERSECURITY

Verifica Unità 1

Cyberspace, cybersecurity aziendale, attaccanti, difensori, sicurezza di rete e web, Capture the Flag. Tempo: 75 minuti. Punteggio totale: 100 punti. Non serve la calcolatrice.

Nome e cognome	Classe	Data

Il caso. Logistica Adriatica (inventata) è un'azienda di trasporti e magazzini con 120 dipendenti e un portale web dove i clienti seguono le spedizioni. Per settore e dimensione rientra nella NIS2 come soggetto importante. Gli esercizi da 3 a 9 si riferiscono a questo caso.

1. Scelta multipla

18 punti · 3 per domanda

Segna una sola risposta per ogni domanda.

a) Un attaccante cambia l'IBAN in una fattura salvata nel gestionale, senza leggere altri documenti. Quale proprietà è violata?

- ○ Riservatezza
- ○ Integrità
- ○ Disponibilità
- ○ Nessuna: non ha rubato dati

b) Attivare la MFA su tutte le caselle di posta riduce soprattutto…

- ○ la probabilità che un account venga violato
- ○ l'impatto di una violazione già avvenuta
- ○ il numero di e-mail di phishing ricevute
- ○ il rischio residuo a zero

c) Nel SOC, il sistema che raccoglie i log di firewall, VPN e server, li correla e genera gli allarmi è…

- ○ il SIEM
- ○ il SOAR
- ○ l'EDR
- ○ il WAF

d) Chi parte da un'ipotesi e cerca nei dati tracce di intrusi che nessun allarme ha segnalato?

- ○ L'analista SOC di primo livello
- ○ Il threat hunter
- ○ Il penetration tester
- ○ Il CISO

e) Quale difesa può bloccare le richieste HTTP che contengono tentativi di SQL injection verso il portale?

- ○ Un packet filter stateless
- ○ Un firewall stateful
- ○ Un WAF
- ○ Una VPN

f) Un cliente, dopo il login, cambia `/api/spedizioni/5120` in `/api/spedizioni/5121` e vede la spedizione di un altro cliente. Categoria OWASP 2021?

- ○ A01 Broken Access Control
- ○ A03 Injection
- ○ A05 Security Misconfiguration
- ○ A07 Identification and Auth. Failures

2. Vero o falso

12 punti · 1,5 per frase

V ☐ F ☐ Secondo la NIS2 gli organi di amministrazione approvano le misure di sicurezza e ne possono essere ritenuti responsabili.

V ☐ F ☐ Con un'assicurazione cyber l'azienda trasferisce all'assicuratore anche la responsabilità verso il Garante e i clienti.

V ☐ F ☐ Un falso negativo è un allarme che scatta per un'attività innocua.

V ☐ F ☐ Una password scritta in Base64 nel file di configurazione è protetta, perché per leggerla serve una chiave.

V ☐ F ☐ Una VPN crea un tunnel cifrato ma, senza MFA, una password rubata basta per entrare nella rete aziendale.

V ☐ F ☐ Nella OWASP Top 10 del 2021 il Cross-Site Scripting fa parte della categoria Injection.

V ☐ F ☐ Chi entra senza permesso in un sistema e poi avvisa il proprietario della falla, in Italia, non commette reato.

V ☐ F ☐ In una CTF Attack-Defense ogni squadra corregge i propri servizi vulnerabili e attacca quelli delle altre.

3. Il registro dei rischi

12 punti

Probabilità P e impatto I vanno da 1 a 5; R = P × I. Soglie: **Alto** da 15, **Medio** da 8 a 14, **Basso** fino a 7.

Asset · minaccia	P	I	R	Livello
R1 Portale clienti · SQL injection	3	4		
R2 E-mail dell'amministrazione · phishing	4	4		
R3 Server del gestionale di magazzino · ransomware	3	5		
R4 Tablet degli autisti · furto	4	2		
R5 Wi-Fi ospiti, separata · accesso non autorizzato	2	3		

a) Completa R e livello *(5 punti)*. b) In Calc R è in E2: scrivi la formula per il livello in F2 *(2 punti)*. c) Scrivi il tipo di trattamento (mitigare, trasferire, evitare, accettare) di ogni decisione: una polizza che copre i costi di un incidente; spegnere il vecchio server FTP esposto che nessuno usa più; lasciare R5 com'è e scriverlo nel registro *(3 punti)*. d) Per R3 l'azienda introduce backup offline provati ogni mese: abbassano P o I? Perché? *(2 punti)*

4. Gli attaccanti e la kill chain

10 punti

a) Scrivi il profilo dell'attaccante: script kiddie, cybercriminale, hacktivista, gruppo statale (APT), insider. *(4 punti)*

Situazione	Profilo
1. Un collettivo rivendica su Telegram un DDoS contro il portale, per protesta contro un contratto con un paese in guerra.	
2. Un ex magazziniere entra nel gestionale con la sua password, mai revocata, e cancella le giacenze.	
3. Un gruppo resta per mesi nella rete di un'azienda della difesa, usa una zero-day e copia progetti; i governi lo attribuiscono a un altro Stato.	
4. Un affiliato usa un ransomware "in affitto" e divide il riscatto con gli sviluppatori.	

b) Un attacco a Logistica Adriatica, in ordine sparso. Scrivi la fase della Cyber Kill Chain di ogni evento. *(6 punti)*

Evento	Fase
1. Il programma contatta ogni 30 minuti un server esterno per ricevere ordini.	
2. L'attaccante prepara un documento Word con una macro malevola, travestito da bolla di consegna.	
3. L'attaccante cifra il gestionale del magazzino e chiede un riscatto.	
4. Il documento arriva per e-mail all'ufficio spedizioni da un finto cliente.	
5. Il codice crea un'attività pianificata che lo riavvia a ogni accensione.	
6. Un impiegato abilita le macro e il codice viene eseguito.	

5. MITRE ATT&CK: quale tattica?

6 punti · 1 per riga

Il rapporto del SOC su un'altra intrusione. Per ogni osservazione scrivi la tattica, scegliendo tra: *Reconnaissance, Initial Access, Execution, Persistence, Privilege Escalation, Credential Access, Discovery, Lateral Movement, Exfiltration, Impact*. Alcune tattiche non servono.

Osservazione	Tattica
1. Un'impiegata riceve una mail con un link a una falsa pagina di login aziendale.	
2. Dal PC compromesso partono migliaia di tentativi di password contro gli account del dominio.	
3. Con il Desktop remoto l'attaccante passa dal PC dell'impiegata al file server.	
4. Crea l'account "backup_svc" per poter rientrare anche se le password vengono cambiate.	
5. Sfrutta una falla non corretta del server per passare da utente normale ad amministratore.	
6. Cifra i file del gestionale e cancella le copie shadow di Windows.	

6. Leggere un log

10 punti

Log del concentratore VPN di Logistica Adriatica, in ordine di tempo. Ogni riga: `ora esito utente ip`.

```
01:58:12 OK   turno_notte 198.51.100.8          02:14:05 OK   fbianchi    203.0.113.45
02:14:01 FAIL admin       203.0.113.45          07:58:40 FAIL lverdi      198.51.100.12
02:14:02 FAIL admin       203.0.113.45          07:58:55 OK   lverdi      198.51.100.12
02:14:02 FAIL administrator 203.0.113.45        08:03:10 FAIL gneri       192.0.2.77
02:14:03 FAIL backup      203.0.113.45          08:03:31 FAIL gneri       192.0.2.77
02:14:04 FAIL fbianchi    203.0.113.45          08:03:52 FAIL gneri       192.0.2.77
02:14:05 FAIL fbianchi    203.0.113.45          08:04:20 FAIL gneri       192.0.2.77
```

a) Quale IP sta facendo un attacco a forza bruta? Indica due indizi presi dal log. *(3 punti)* b) L'attacco è riuscito? Con quale account e a che ora? *(2 punti)*

c) Applica a mano la regola del mini-SIEM del laboratorio: per ogni IP si contano gli accessi falliti consecutivi; con almeno 3 falliti seguiti da un OK dallo stesso IP scatta un allarme **ALTO**, con almeno 3 falliti e nessun OK un allarme **MEDIO**. Quali allarmi scattano, e per quali IP nessuno? *(3 punti)*

d) Tattica e tecnica ATT&CK dell'attacco; una contromisura che avrebbe impedito l'accesso anche con la password giusta. *(2 punti)*

7. Risposta all'incidente e NIS2

10 punti

a) Scrivi accanto a ogni azione la fase della risposta: preparazione, identificazione, contenimento, eradicazione, ripristino, lezioni apprese. *(6 punti)*

Azione	Fase
A. Si scollega dalla rete il server del gestionale e si disabilita l'account fbianchi.	
B. Si rimuovono l'attività pianificata del malware e l'account creato dall'attaccante; si applica la patch.	
C. Mesi prima: si scrivono il piano e i contatti di reperibilità e si fa un'esercitazione tabletop.	
D. Si rimette in funzione il gestionale dai backup offline e lo si tiene sotto osservazione.	
E. L'analista conferma che gli accessi delle 02:14 non erano di fbianchi e valuta quali sistemi sono coinvolti.	
F. Si attiva la MFA su tutta la VPN e si aggiorna il piano con ciò che non ha funzionato.	

b) L'azienda viene a conoscenza dell'incidente significativo **giovedì alle 10:00**. A chi va notificato secondo la NIS2? Entro quando vanno inviati preallarme, notifica e relazione finale? *(3 punti)*
c) Sono stati copiati anche nomi, indirizzi e telefoni di 3 000 clienti. Serve un'altra notifica? A chi ed entro quando? *(1 punto)*

8. Firewall, segmentazione, VPN

8 punti

Segmenti: Internet, DMZ (portale clienti su TCP 443), Uffici, Magazzino, Ospiti. Requisiti: da Internet si raggiunge solo il portale; Ospiti e Magazzino non raggiungono gli Uffici; chi viola il portale non deve arrivare agli Uffici. Le regole si leggono dall'alto: vince la prima che corrisponde, le risposte alle connessioni consentite passano (firewall stateful).

N.	Origine	Destinazione	Servizio	Azione
1	Internet	DMZ, portale	TCP 443	Consenti
2	Ospiti	qualsiasi	qualsiasi	Consenti
3	Uffici	Internet	TCP 80, 443 e DNS	Consenti
4	Magazzino	Internet	TCP 80, 443 e DNS	Consenti
5	DMZ	Uffici	qualsiasi	Consenti
6	Magazzino	Uffici	qualsiasi	Blocca
7	qualsiasi	qualsiasi	qualsiasi	Blocca

a) Trova le **due regole sbagliate**, spiega quale requisito violano e correggile. *(4 punti)*

b) Per ogni esigenza scegli la soluzione più adatta tra VPN con MFA, WAF, segmentazione con VLAN, firewall stateful. *(4 punti)*
1) Gli autisti consultano da fuori sede il gestionale interno. 2) Fermare le richieste con SQL injection verso il portale mentre gli sviluppatori correggono il codice. 3) Un PC del magazzino infetto non deve poter raggiungere la contabilità. 4) La risposta di un sito visitato da un impiegato deve entrare, un pacchetto non richiesto no.

9. OWASP Top 10: riconosci e correggi

8 punti · 2 per riga

OWASP Top 10 2021: A01 Broken Access Control · A02 Cryptographic Failures · A03 Injection · A04 Insecure Design · A05 Security Misconfiguration · A06 Vulnerable and Outdated Components · A07 Identification and Authentication Failures · A08 Software and Data Integrity Failures · A09 Security Logging and Monitoring Failures · A10 Server-Side Request Forgery

Problema nel portale	Categoria	Correzione
1. La ricerca di una spedizione inserisce il codice scritto dall'utente direttamente nel testo della query SQL.		
2. Le password dei clienti sono salvate nel database in chiaro.		
3. Il login accetta tentativi illimitati e non offre la MFA.		
4. Il portale usa una versione vecchia di una libreria con una vulnerabilità nota, corretta da mesi.		

10. Capture the Flag ed etica

6 punti

a) Scrivi la categoria CTF di ogni sfida: web, crypto, forensics, reverse, pwn, OSINT. *(4 punti)*
1) Ricevi una cattura di rete .pcap e devi trovare il file trasferito. _____ 2) Un programma compilato chiede una password: devi capire che cosa controlla senza avere il sorgente. _____ 3) Un messaggio è cifrato con il cifrario di Cesare con chiave sconosciuta. _____ 4) Il sito della sfida usa un cookie `ruolo=utente` che si può modificare. _____

b) Usando normalmente il registro elettronico ti accorgi che, cambiando un numero nell'indirizzo, vedi i voti di un altro studente. Che cosa fai, che cosa non fai e perché? *(2 punti)*

Punti: _____ / 100 **Voto: _____**